跨国企业个人信息出境合规实务指引（2026 版）
——从“合规负担”向“合规竞争力”的转化
(Cross-Border Data Transfer Compliance Guide for Multinational Enterprises: Transforming Compliance Burden into Competitive Advantage)

一、 执行摘要 (Executive Summary)

在全球数字经济步入“存量博弈”与“主权加固”并行的 2026 年，个人信息跨境流动的合规性已不再仅仅是企业的法务合规成本，而是衡量其全球运营韧性与品牌公信力的核心指标。中国《个人信息保护法》（PIPL）及其配套的《数据出境安全评估办法》、《个人信息出境标准合同办法》以及 2026 年全面落地的《个人信息出境认证办法》，共同构建了一个既严密又具备场景化灵活度的监管闭环。

在监管背景方面，中国法律体系正处于从“条文创制”向“精准执法”的转型期。2025 年 5 月上海公安机关对某欧洲奢侈品牌未经合规即跨境传输数据的处罚，标志着监管已经下沉至日常行政执法层面。与此同时，欧盟 GDPR 在人工智能治理与数据主权方面的激进姿态，使得跨国企业在处理“境内收集、总部决策”的业务逻辑时，必须面对严峻的法律冲突。

本指南立足于 2024 年《促进和规范数据跨境流动规定》所确立的“豁免+备案+评估”三支柱框架，通过对以 TikTok Shop 为代表的全球化电商模式及外企 HR 管理（Workday/SAP 场景）的深度解构，提供一套在 2026 年复杂地缘政治环境下可落地的风险识别与路径选择方案。其核心逻辑聚焦于四个支柱：数据映射（Data Mapping）的颗粒度还原、安全评估（Security Assessment）的动态申报、标准合同（SCC）的备案执行、以及最小必要（Minimum Necessity）原则的技术锁闭。

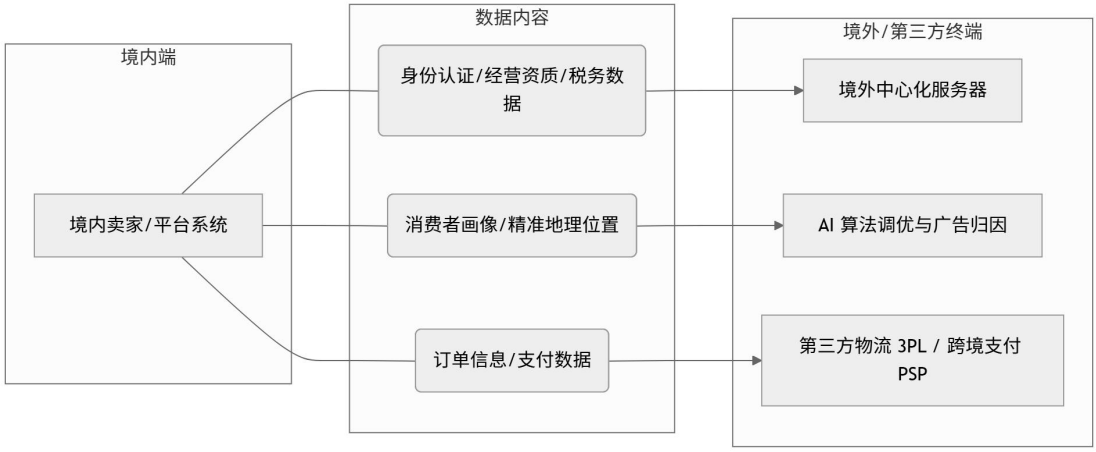
二、 核心业务场景风险穿透 (Business Scenario Mapping)

在跨国企业的日常运营中，数据并非静止的资产，而是流动的生产要素，其风险往往隐藏在复杂的业务网络中。

以全球化电商平台为例（见图 1），其业务涉及境内卖家（Sellers）与境外消费者（Consumers）的双向交互，以及境内消费者画像数据向境外中心化服务

器的同步。在境内卖家出海场景下，数据流向主要包括卖家身份认证、经营资质、税务信息及仓储物流数据。这些数据一旦进入跨境流转，便涉及第三方物流供应商（3PL）和跨境支付服务商（PSP）的二次处理 。根据 2026 年的最新监管趋势，如果 PSP 在境外进行反洗钱审计或欺诈检测，其获取的数据颗粒度可能触及敏感个人信息（如银行账户）。根据最新的《认证办法》，此类链条式处理要求企业必须在合同中明确“延伸审计权[1]”，确保境外三方机构的操作不超出初始授权范围。

在针对境内消费者的行为追踪场景下，TikTok Shop 利用设备数据采集工具（DDCTs），如 Pixel、SDK 和 API，实时抓取用户的精准地理位置、浏览偏好、交易频率等。2025 年后的政策变动强调了对“精准地理位置”的强监管，将其视为敏感个人信息。若通过算法进行画像并跨境传输，必须在前端界面实现“单独同意”（Separate Consent），而非笼统的隐私政策勾选。此外，2026 年的技术趋势显示，AI 代理（Agentic AI）开始介入电商决策，这要求企业必须对 AI 模型训练过程中涉及的数据跨境进行 PIPIA 评估，防止数据在境外被用于未经披露的算法调优。



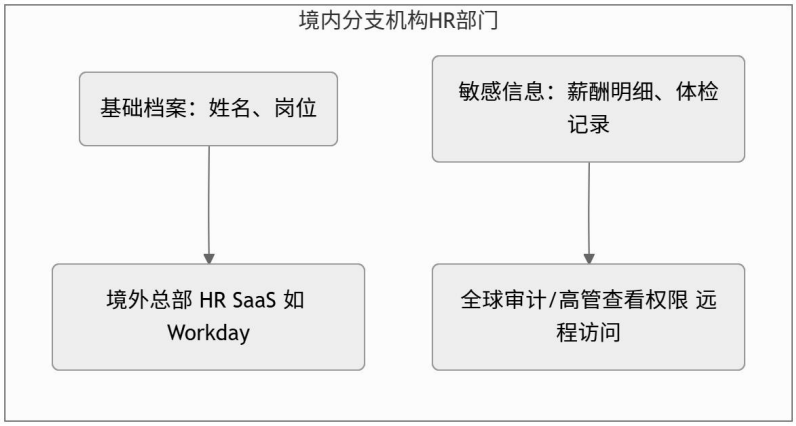
图一

在另一个典型的跨国企业全球人力资源管理场景中（见图二），企业倾向于使用 Workday 或 SAP 等中心化云平台。境内分支机构的员工基础档案、绩效评估及薪酬体检等敏感数据往往单向流向境外总部的 SaaS 系统。尽管 2024 年《规

[1] 《中华人民共和国审计法》第三十三条第一款：“审计机关进行审计时，有权就审计事项的有关问题向有关单位和个人进行调查，并取得有关证明材料。有关单位和个人应当支持、协助审计机关工作，如实向审计机关反映情况，提供有关证明材料。”

定》为“跨境人力资源管理必需”提供了豁免路径，但在 2026 年的实务操作中，这一豁免的适用边界正在收缩。监管机构在 2025 年的最新 FAQ 中指出，该豁免仅适用于“维持劳动关系所必需”的基本信息。如果总部利用员工绩效数据进行全球人才池的 AI 建模，或者涉及大规模的敏感个人信息（如针对外籍员工的背景调查、涉及种族或宗教的分类数据），则必须回归 SCC 备案或认证路径（见表一）。

一个显著的合规陷阱在于“海外人员远程访问”。根据 2025 年 6 月发布的《数据出境安全评估申报指南（第三版）》，即使数据物理上存储在境内（如本地部署的服务器），但若境外总部员工拥有远程查看权限，即被视为“数据出境”。对于采用混合办公模式的跨国公司，这意味着必须建立严格的零信任架构（Zero Trust Architecture），通过细粒度的角色访问控制（RBAC）将“必要访问”限制在最小范围。



图二

HR 数据类别	出境必要性分析 (Necessity Analysis)	合规建议 (Compliance Advice)
基础档案 （姓名、岗位）	极高（组织架构管理）	适用“HR 管理必需”豁免路径
薪酬财务信息	高（全球审计与税务核算）	需进行 PIPIA，识别敏感信息
体检与健康记录	低（通常非管理必需）	建议本地化存储，禁止出境
绩效与潜力评分	中（职业发展规划）	若涉及 AI 决策，需获单

		独同意

表一

三、 法律风险矩阵与监管红线 (Risk Matrix)

构建合规防线的基石在于建立一套基于中国数据跨境“3+1=4”法律框架（即《中华人民共和国网络安全法》、《中华人民共和国数据安全法》《中华人民共和国个人信息保护法》三大上位法，以及《网络数据安全管理条例》《数据出境安全评估办法》《个人信息出境标准合同办法》《个人信息出境认证办法》《促进和规范数据跨境流动规定》等配套规章）的量化风险识别模型。

根据上述最新规定，企业在满足特定条件时将触碰强制向国家网信部门申报数据出境安全评估的监管高压线。具体而言，若企业被相关部门正式认定为关键信息基础设施运营者，其收集和产生的个人信息与重要数据出境必须无条件通过安全评估；对于非关键信息基础设施运营者，若向境外提供被行业主管部门、地区告知或公开发布为重要数据，必须在接到认定通知后两个月内申报安全评估，并在评估完成前暂停出境活动。在个人信息规模与敏感度方面，非关键信息基础设施运营者自当年一月一日起，累计向境外提供超过一百万人个人信息（不含敏感个人信息），或累计向境外提供超过一万人敏感个人信息，同样强制触发安全评估。未达到上述海量数据或高敏感门槛的非关键信息基础设施运营者，例如向境外提供十万人以上但不足一百万人的一般个人信息，或不满一万人敏感个人信息，则应当依法选择订立个人信息出境标准合同并向省级网信办备案，或通过个人信息保护认证。需要特别警惕的是，即便服务器物理地址完全位于中国境内，境外人员对境内系统的远程访问与查看，在监管口径上同样被实质性地视为数据出境行为（见表二）。

数据处理者属性	**数据类型**	**数据规模（当年 1 月 1 日起累计）**	**法定推荐合规路径**
非 CIIO	一般个人信息	< 10 万人	免予申报出境机制 (依据《规定》低数量豁免)
非 CIIO	一般个人信息	10 万人 - 100 万人	订立标准合同 (SCC) 或 保护认

			证
非 CIIO	敏感个人信息	< 1 万人	订立标准合同 (SCC) 或 保护认证
非 CIIO	个人信息/敏感信息	≥ 100 万人 / ≥ 1 万人	国家网信部门数据出境安全评估
非 CIIO	重要数据	不限规模	国家网信部门数据出境安全评估
CIIO	个人信息或重要数据	不限规模	国家网信部门数据出境安全评估

见表二

在 2026 年的法律实务中，数学公式可用于计算累计出境风险值：

$$Risk_Value = \sum_{i=1}^{n}(V_i \times S_i) + 1_{CIIO} \times \infty$$

其中 V_i 为第 i 类数据的年度累计人数，Si 为数据的敏感度权重。当 Risk_Value 超过法定阈值，或者主体被标记为 CIIO（$1_{CIIO}=1$），则评估成为法定强制义务。

一旦触碰上述监管红线且未落实相应合规动作，企业将面临极高的法律、经济与声誉风险。依据《中华人民共和国个人信息保护法》第六十六条的明确规定，违规企业可能面临最高达五千万元人民币或上一年度营业额百分之五的经济重罚，并可能被处以没收违法所得、责令暂停相关业务、停业整顿、吊销营业执照以及责令暂停或终止应用程序服务等极其严厉的行政制裁。同时，监管部门在执法中实施严格的双罚制，对直接负责的主管人员和其他直接责任人员不仅处以十万元以上一百万元以下的个人罚款，还可明令禁止其在一定期限内担任相关企业的高管及个人信息保护负责人。在极端违规情形下，例如非法采集并向境外传输高铁信号等涉及国家核心安全的重要数据，甚至可能突破行政处罚的范畴，直接触发刑事责任追究。

在划定严格监管红线的同时，2024 年出台的《促进和规范数据跨境流动规定》也为企业提供了动态合规的豁免空间。该规定引入了场景化豁免机制，对于

为订立或履行个人作为一方当事人的跨境购物、跨境寄递、跨境汇款、跨境支付、机票酒店预订等合同所必需，以及按照依法制定的劳动规章制度和集体合同实施跨境人力资源管理所必需的数据跨境流动，且当年累计向境外提供不满十万人个人信息的，免予申报数据出境安全评估、订立个人信息出境标准合同或通过个人信息保护认证。此外，纯粹的数据过境（处理过程中未引入境内个人信息或重要数据）以及紧急情况下为保护生命财产安全的场景也享有同等豁免待遇。然而，监管机构明确强调，上述豁免情形必须被严格地狭义解释。以人力资源跨境管理豁免为例，数据范围必须严格限制在与维持劳动关系直接相关的最小必需范围内，企业不得未经核查随意将员工的身份证件、护照、银行账户或体检报告等高风险敏感信息传输至境外。此外，适用此类豁免仅代表免除特定出境机制的行政申报程序，企业仍不可推卸地需要履行事前个人信息保护影响评估（PIA）以及获取用户单独同意等法定前置义务。在此基础之上，各自由贸易试验区如天津、北京、上海、广西等在国家数据分类分级保护制度框架下自行制定了数据出境负面清单，向境外提供负面清单之外的数据可完全免除上述三大出境机制的约束，这为跨国企业在华的业务布局及合规降本提供了极大的政策优势与竞争力转化契机。

四、 企业合规落地“三步走”策略 (Compliance Action Plan)

面对复杂的监管环境，企业合规落地需要采取系统化的三步走推进策略。

（一）第一步：数据底数梳理 (Data Inventory)

在第一阶段的数据底数梳理中，企业首要任务是打破业务部门与 IT 部门之间的信息壁垒，运用自动化数据发现与标签技术，建立动态可视化的数据流转地图。这不仅仅是简单记录数据的收集源与接收方，更要求精准穿透物理流转与逻辑访问权限，特别是要排查出业务链条中极易被忽视的“境外人员远程访问境内服务器”这一实质性出境行为。企业需对数据进行严格的分类分级，清晰界定哪些属于一般个人信息，哪些触及了金融账户、行踪轨迹等敏感个人信息乃至国家重要数据，同时深挖并清理隐蔽的影子 IT 系统，最终输出一份详尽且包含处理目的、体量与留存期的企业跨境数据流转清单，为后续的合规决策提供绝对坚实的事实基础。

（二）第二步：合规路径选择 (Path Selection)

基于上述扎实的数据底数，企业随后进入合规路径的精准选择阶段。对于涉

及关键信息基础设施运营者、处理重要数据，或自当年一月一日起累计向境外提供超过一百万人一般个人信息、一万人敏感个人信息的海量及高风险场景，企业必须毫不犹豫地通过国家网信部门的数据出境申报系统，正式发起数据出境安全评估。该路径虽审查严苛，但能提供最高级别的合规背书。而对于向境外提供十万人以上、不满一百万人的一般个人信息等中等规模场景，严格采用国家网信办制定的标准合同（SCC）模板与境外接收方签约，并在法定期限内向省级网信办完成备案，是普适且高效的最优解（见表三）。更为关键的是，企业应具备商业前瞻性，积极适用二零二四年《促进和规范数据跨境流动规定》中的豁免红利。例如，在跨境电商履行个人合同或外企实施依法制定的跨境人力资源管理场景下，只要经过严密论证，确保出境数据严格限制在与业务直接相关且最小必要的范围内，即可依法免予申报；同时，企业还可战略性地利用广西、上海等自贸试验区发布的数据出境负面清单，清单外数据可自由流转，从而大幅度实现合规降本与业务提效。

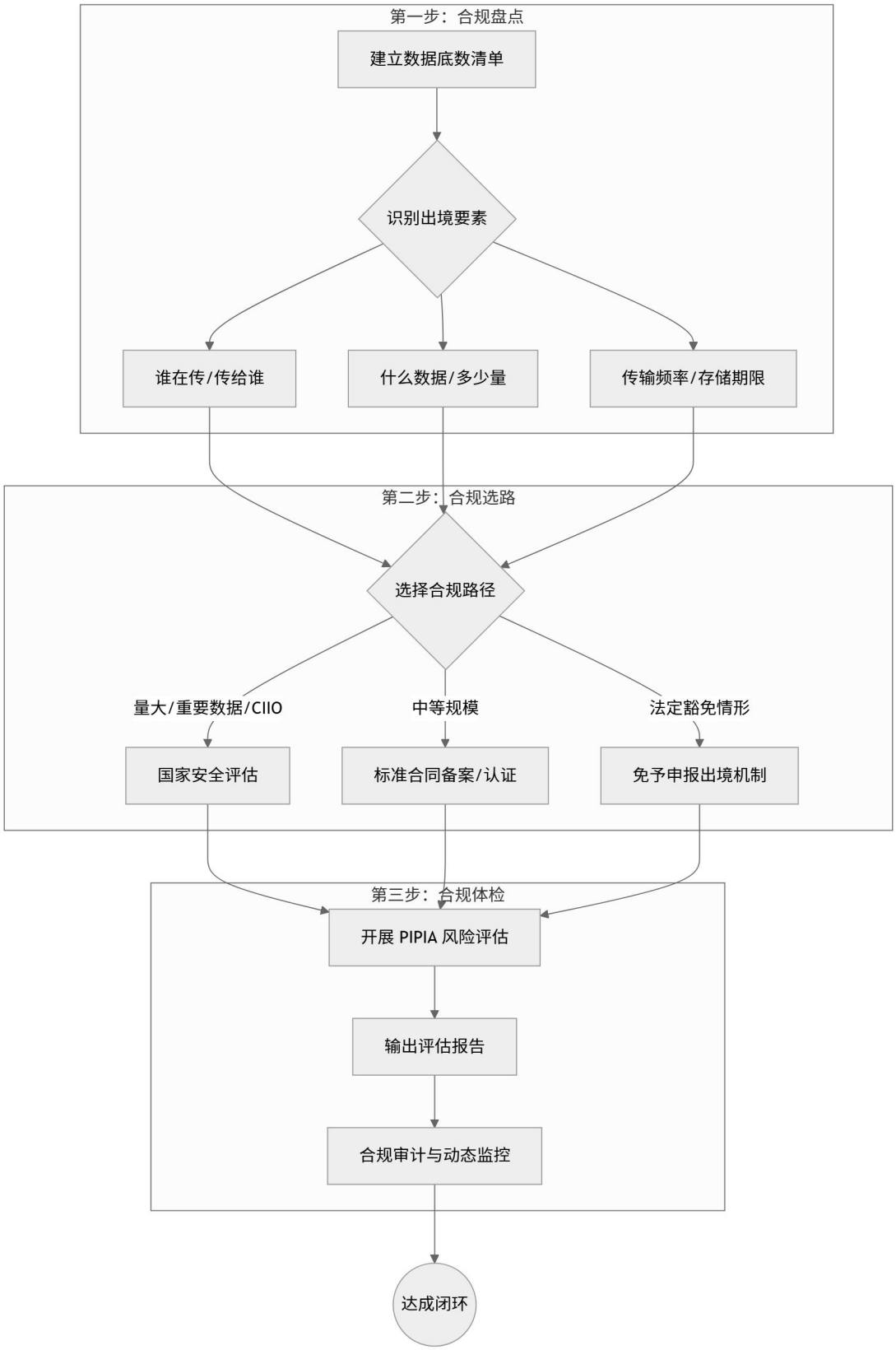
路径 (Path)	适用场景 (Applicability)	成本与周期 (Cost & Timeline)
国家安全评估	海量数据、CIIO、重要数据	高；6 个月以上
标准合同备案 (SCC)	10 万至 100 万个人信息；1 万人以下敏感个人信息	中；2-3 个月
安全认证 (Certification)	集团内跨境流转、长期稳定项目	高（初始）；持续有效
豁免情形	跨境消费必需、HR 必需、低数量	极低

表三

（三）第三步：个人信息保护影响评估 (PIA/DPIA)

无论企业最终匹配何种出境路径，事前开展个人信息保护影响评估（PIA）都是一条不可逾越的法定前置红线。在这一阶段，企业不能仅停留在内部合规视角的自查，而必须将评估视野拓展至全球。企业需要深入剖析数据处理目的及方式的正当性与必要性，详尽评估出境活动对个人权益可能造成的潜在影响，判断

是否存在数据被拦截、非法分析、甚至危害人身财产安全的风险，并重点对境外接收方所在国家或地区的法律环境进行实质性安全风险测算，防范因当地公权力过度调取数据而引发的跨国法律冲突。为实质性降低这些风险，企业必须在评估中审查并固化一系列技术保护措施的有效性，如采用 AES-256 加密、TLS 1.2+ 传输协议以及可靠的数据去标识化或匿名化技术。最终，这些完整的评估逻辑、事实依据与技术证明必须汇编成满足 GB/T 39335 要求的《个人信息保护影响评估报告》，并严格落实至少留存三年备查的法律义务，以此构建起企业应对监管倒查与外部信任危机的核心防御体系。


第一步：合规盘点
建立数据底数清单
识别出境要素
谁在传/传给谁
什么数据/多少量
传输频率/存储期限
第二步：合规选路
选择合规路径
量大/重要数据/CIIO
中等规模
法定豁免情形
国家安全评估
标准合同备案/认证
免予申报出境机制
第三步：合规体检
开展 PIPIA 风险评估
输出评估报告
合规审计与动态监控
达成闭环

五、 结论：构建韧性合规体系 (Building Resilience)

数据跨境合规并非一次性的项目验收，而是需要深度嵌入企业业务基因的动态治理过程。

首先，企业应建立“法务-技术-业务”三位一体的协同机制。法务制定规则，技术通过代码实现“隐私保护嵌入”（Privacy by Design），业务在规则框架内寻找最优增长路径。在业务拓展的初期阶段，就应当植入隐私保护设计的理念，通过完善的自动化系统持续监控数据流转状态。在日常管理和新项目启动前，企业应当建立一套完善的内部初筛机制。这要求团队时刻自查是否已被认定为关键信息基础设施运营者，拟出境数据是否包含重要数据或触及百万规模阈值。同时，必须审慎排查是否涉及金融、行踪或未成年人等敏感个人信息，以及是否依法获取了单独同意或满足豁免的严格限制条件。此外，企业还需确认是否已出具并留存了 PIA 报告，是否与境外接收方签署了标准合同，以及是否对境外远程访问权限和传输存储加密等技术隔离措施进行了妥善管控。

其次，重视自贸区（FTZ）的制度红利。上海临港、天津、北京、海南等自贸区已陆续出台“负面清单”。清单之外的数据可以更自由地流动。跨国公司应考虑将其数据处理中心设立在这些区域，以获取政策上的绿色通道。

最后，应对“AI 时代”的数据主权。随着 Agentic AI 在 2026 年的爆发，数据出境的形式更加隐蔽（如模型权重的跨境同步）。企业必须将合规视野扩展到 AI 治理领域，确保算法的每一次“出境”都具备法律依据。合规不仅是守法，更是企业在全球数字化浪潮中生存并壮大的基石。

附录：跨境数据合规初筛 10 问 (Compliance Checklist)

为方便业务与技术部门快速自查，请在启动涉及跨境数据交互的新项目前，完成以下问题的勾选确认：

[ ] 主体性质：我们是否已被相关部门通知认定为“关键信息基础设施运营者(CIIO)”？

[ ] 数据红线：我们拟出境的数据字段中，是否包含了被行业主管机关定义的“重要数据”？

[ ] 规模阈值：自今年 1 月 1 日起算，我们向境外提供个人信息的累计人数是否已经（或即将）超过 100 万人次？

[ ] 敏感信息：我们传输的数据中，是否涉及金融账户、行踪轨迹、体检记录或不满 14 周岁未成年人等“敏感个人信息”？

[ ] 单独同意：若不属于法定豁免情形，我们是否已在前端页面向用户充分告知了境外接收方详情，并获取了用户的单独同意(SeparateConsent)？

[ ] 豁免评估：若主张“履行合同所必需”或“跨境 HR 管理必需”进行豁免，该数据量是否被严格限制在了最小必要的范围内？

[ ] PIA 报告：在数据出境前，我们是否已经完成了《个人信息保护影响评估(PIPIA)》，并将报告及记录归档（留存期三年）？

[ ] 合同约束：我们是否与境外接收方或第三方供应商签署了符合国家网信办模板的《数据出境标准合同(SCC)》或包含同等效力的 DPA 条款？

[ ] 远程权限：我们存放在中国境内的服务器或数据库，是否向境外的技术支持团队、总部高管等人员开放了远程调取、查看或导出的权限？

[ ] 技术隔离：在数据传输与存储过程中，我们是否部署了满足安全标准（如 TLS1.2+、AES-256）的加密措施，并实施了基于角色的最小权限访问控制(RBAC)？